

Audit Plan

Audit Scope:

The scope of this audit is to assess the design and operating effectiveness of the organization's Information Technology General Controls (ITGCs) related to User Access Management, Password Controls, Backup Controls, Change Management, Antivirus, and Logging & Monitoring.

Audit Objective:

The audit will determine whether these controls adequately protect information systems from unauthorized access, data loss, system compromise, and operational disruptions.

Control Area	Risk	Audit Procedure	Evidence Required
User Access Management	- Excessive privileged user access - Orphaned accounts	- Obtain a list of all users - Review user provisioning, modifications, and termination process	- User listing - Access control forms - HR employee forms - Termination records - Privileged access report
Password Controls	- No MFA enforced - Weak password complexity	- Review password policy settings - Verify password complexity - Review MFA requirements - Compare against company policy	- Password policy - GPO screenshots - Active Directory settings - MFA configuration - Security standards
Backup Controls	No regular backup testing	- Review backup procedures - Verify backup schedules - Off-site / Cloud storage - Encryption - Restoration testing - Inspect evidence of successful backup jobs and restore tests	- Backup policy - Backup logs - Backup schedules - Restore test reports - Backup software reports - Screenshots of successful backups

Change Management	• Change process not documented	• Review change management policy • Select a sample of production changes and verify change request, business approval, testing, implementation, approval, and post-implementation review • Check emergency changes separately	• Change requests • Approvals • Testing evidence • Implementation plans • CAB meeting minutes • Change logs • Rollback plans
Antivirus	• No active antivirus license in use	• Review endpoint protection configuration • Verify antivirus is installed on all devices • Verify scans are scheduled • Verify alerts are monitored • Sample endpoints for compliance	• Antivirus dashboard reports • Update logs • Scan reports • Endpoint inventory • Incident reports • Screenshots
Logging and Monitoring	• Security incidents not logged • No monitoring system in place	• Review logging configuration • Verify critical systems generate logs, logs are retained, monitoring alerts are reviewed, and incidents are investigated • Sample security events and trace them to incident records	• SIEM reports • Windows Event Logs • Firewall Logs • Monitoring Dashboards • Incident tickets • Alert reports • Log retention policy